UNIVERSIDAD DE SANTIAGO DE CHILE
FACULTAD DE INGENIERIA
Departamento de Ingeniería Eléctrica

ANEXO : Propuesta de diseño bajo normativa IEC 62443-2-4 a redes SCADA del SIC y SING

Jose Maria Andoni Zalvidea Romero

Profesor Guía:
Javier Alfredo Rivera Castillo

Memoria para optar el título de Ingeniero de ejecución en Electricidad

Santiago – Chile
2024

TABLA DE CONTENIDO

ÍNDICE DE FIGURAS ..... **ii**

1. **DESCRIPCIÓN DE ANEXO Y FUNCIONAMIENTO DE PLATAFORMA XDR** **1**

1.1 ORIGEN Y NECESIDAD 1

1.1.1 OBJETIVO GENERAL 1

1.1.2 OBJETIVOS ESPECIFICOS 1

1.2 DESCRIPCION DE ESCENARIO 1

1.2.1 XDR Wazuh: Arquitectura y funcionamiento 2

2. **ESCENARIO DE ENSAYO Y PRUEBAS DE PLATAFORMA WAZUH** **4**

2.1 DESCRIPCIÓN DE ESCENARIO 4

2.2 Detección de ataque de Fuerza Bruta: Configuración por defecto 4

2.3 Implementación IDS Suricata 7

2.4 IMPLEMENTACION DE VIRUS TOTAL 11

2.5 DETECCION DE RASGOS DE DOS A TRAVÉS DE IDS SURICATA 16

3. **CONCLUSIONES** **25**

GLOSARIO **26**

REFERENCIAS BIBLIOGRÁFICAS **27**

CONFIGURACION DE HERRAMIENTAS DE WAZUH **29**

A.1 IMPLEMENTACIÓN Y CONFIGURACIÓN IDS SURICATA 29

A.2 CONFIGURACION DE VIRUSTOTAL 31

A.2.1 CONFIGURACIÓN DE VIRUSTOTAL EN HOST 31

A.2.2 CONFIGURACIÓN DE VIRUSTOTAL EN SERVIDOR WAZUH 33

A.3 FICHA TECNICA DIODO DE DATOS XD VERGE .. **¡Error! Marcador no definido.**

A.4 FICHA TECNICA DIODO DE DATOS XD VERGE .. **¡Error! Marcador no definido.**

ÍNDICE DE FIGURAS

Figura 1.1. Arquitectura de Wazuh [6] 3
Figura 2.1. Registro de intentos de autenticación 5
Figura 2.2. Registros de correlación entre fuerza bruta y utilización de usuario no existente. 6
Figura 2.3 Detalle del reporte de alerta de ataque de fuerza bruta con usuario no existente. 7
Figura 2.4 Identificación de la sub red. 8
Figura 2.5 Identificación de puertos. 9
Figura 2.6a. Registro en el cual NO se alerta de actividad de red maliciosa. 10
Figura 2.7. Registro en el cual NO se alerta de actividad de red maliciosa. 10
Figura 2.8. Escaneo activo para descubrir el sistema operativo objetivo. 11
Figura 2.9. Alertas de actividad maliciosa de consultas por sistema operativo. 11
Figura 2.10. Detección de archivo EICAR y mensajes de respuesta activa aplicada al archivo malicioso. 13
Figura 2.11. Detalle del mensaje de alerta y repositorio de información de amenazas de virustotal. 13
Figura 2.12. Base de datos de VirusTotal [3] donde indica base de datos de herramientas anti virus y antimalware y capacidad de detección de archivo de pruebas EICAR. 14
Figura 2.13. Softwares que no detectan rasgos de EICAR como archivo malicioso en verde, según base de datos de VirusTotal [3]. 14
Figura 2.14. Mensaje de respuesta activa de eliminación de EICAR del host Ubuntu. 15
Figura 2.15. Clasificación de cualidad de amenazas de EICAR según MITRE. 16
Figura 2.16. Comando herramienta hping3 en Kali Linux para ensayo de DOS en Host Ubuntu. 17
Figura 2.17. Detección de tráfico de red sospechoso. 18
Figura 2.18. Evidencia de dirección IPv4 de origen distinta a la dirección del atacante. 19
Figura 2.19. Segunda comprobación de que dirección IPv4 no corresponde a la dirección del atacante. 20
Figura 2.20. Desbordamiento de eventos en memoria de agente wazuh. 21
Figura 2.21. Memoria de Agente wazuh ssturada por efectos de DOS. 22
Figura 2.22. Procesador en operación normal, indicado en recuadro dorado. 23
Figura 2.23. Desbordamiento de procesador de Host Ubuntu. 23
Figura 2.24. Efecto de paralización de Host cuando se solicita servicio de internet en firefox. .. 24
Figura 2.25. Tiempo de respuesta superado, síntoma usual de un DOS en un sitio web. 24

CAPÍTULO 1

DESCRIPCIÓN DE ANEXO Y FUNCIONAMIENTO DE PLATAFORMA XDR

1.1 ORIGEN Y NECESIDAD

En virtud de la orientación del trabajo de titulación, se agrega anexo complementario para la aportación del análisis respecto a temas de ciberseguridad en redes SCADA. En particular dicha aportación es recomendable aplicarla en los niveles 4 y 5 del Modelo Purdue [7].

1.1.1 OBJETIVO GENERAL

Implementar XDR Wazuh [6] y estudiar su capacidad de respuesta y monitoreo frente a distintos escenarios de amenaza

1.1.2 OBJETIVOS ESPECIFICOS

- Verificar la identificación de trafico de red malicioso mediante la implementación de IDS suricata.
- Comprobar las capacidades de Wazuh [6] como XDR y como SIEM por defecto
- Probar la sensibilidad de monitoreo en fases de reconocimiento de la red (escaneo activo).
- Verificar la capacidad de alertar y reconocer patrones maliciosos dentro del host UBUNTU [].
- Realizar pruebas de DOS a un host Ubuntu y medir las capacidades de Wazuh de monitoreo sobre el host mediante IDS Suricata [2], y monitorear mediante Wazuh [6] la experiencia de DOS en el Host Ubuntu, en un rol de SIEM.

1.2 DESCRIPCION DE ESCENARIO

Se establecerá un escenario que será compuesto por 3 máquinas virtuales soportadas en Virtualbox:

- Host Ubuntu 24.04 LTS
- Kali Linux (máquina del atacante)
- Servidor Wazuh

En la siguiente sección se explicará el modelo básico de funcionamiento y arquitectura de Wazuh [6] y así poder entender los procesos y análisis que se expondrán durante el anexo.

1.2.1 XDR Wazuh: Arquitectura y funcionamiento

La plataforma Wazuh [1] [6] se compone de los siguientes elementos:

Servidor Wazuh:

El que mantiene y gestiona los Cluster servers, que analizan la información, la correlacionan, y de acuerdo a ello exponen las alertas en la plataforma hacia un dashboard, para su interpretación o intervención por el especialista encargado de analizar los eventos de seguridad ocurridos en el punto final de terminado.

También correlaciona patrones de comportamiento sobre la actividad del punto final y tiene visión completa de la actividad de este mediante el agente, el que se encuentra implementado en el o los puntos finales que se encuentren siendo monitorizados.

Indexador Wazuh:

Siendo parte integrante del servidor, es el servicio que permite realizar búsqueda y almacenamiento de los eventos ocurridos en los puntos finales y así crear un historial de comportamiento y eventos en el tiempo.

Servicio de gestión:

O conocido como el manager Wazuh, es el que realiza la correlación, análisis y genera las acciones de respuesta (si se encuentran configuradas) para incidir sobre los eventos de seguridad en los puntos finales.

Dashboard:

Interfaz gráfica, mediante la cual es posible ingresar al servidor Wazuh e interactuar con todos los servicios que son soportados en el. En particular se configuran los paquetes de instalación de agentes para ser implementados en determinados puntos finales. En particular, y a través del servicio de despliegue de agentes, Wazuh a través del dashboard aporta los comandos exactos de instalación de paquetes del agente al punto final, para ser introducidos a posterior en la terminal de línea de comandas del Host Ubuntu, por ejemplo.

Agente Wazuh:

Es la extensión de wazuh en el punto final, el que se encarga de comunicar los eventos ocurridos en el punto final, sean actos legítimos (configurado así por defecto) o actos no legítimos o sospechosos. Además, realiza tareas de inventariado automatizado sobre el punto final y envía esta información al servidor Wazuh para su análisis y posteriormente el mismo servidor es quien consulta fuentes de información como CVE (Common Vulnerability expousourse) para alertar sobre las amenazas que actualmente se encuentran vigentes para el punto final y así informar a los responsables de seguridad de redes.

En la Figura 1 se observa la interconexión entre cada servicio.

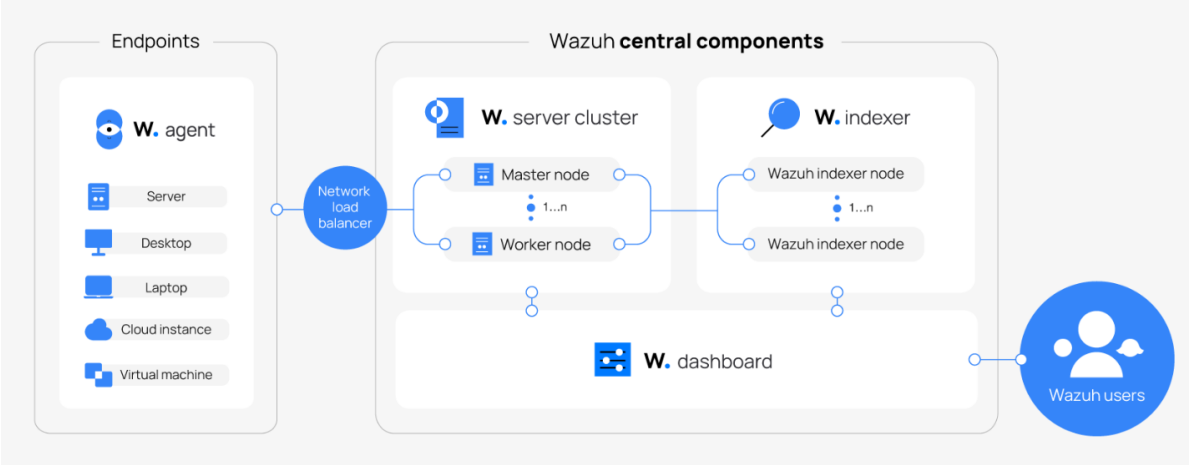


Figura 1.1. Arquitectura de Wazuh [6]

CAPÍTULO 2

ESCENARIO DE ENSAYO Y PRUEBAS DE PLATAFORMA WAZUH

2.1 DESCRIPCIÓN DE ESCENARIO

Se instalan 3 máquinas virtuales a través del gestor de máquinas virtuales VirtualBox [8], para poder representar una subred de ensayo:

1. **Un Host virtual con Sistemas operativo Ubuntu 24.04**, que será el computador que nos interesa monitorear.
2. **Un host Kali Linux**, que realizará los ensayos como atacante.
3. **Servidor Wazuh**, el que recibirá los eventos que perciba el agente emplazado en host Ubuntu.

Con las siguientes direcciones IP para cada máquina virtual:

- **Ubuntu : 192.168.122.156/24**
- **Kali Linux : 192.168.122.229/24**
- **Servidor Wazuh : 192.168.122.206/24**

NOTA: Es importante tener en cuenta las direcciones IP recién expuestas, ya que se observarán durante los ensayos.

2.2 Detección de ataque de Fuerza Bruta: Configuración por defecto

El ataque de fuerza bruta se caracteriza por su alto flujo de red. Dado el alto flujo de datos intentando lograr una autenticación exitosa con el par Usuario/Clave, hasta acertar con el par correcto. En particular se ensaya un tipo de ataque de fuerza bruta denominado “ataque de diccionario”. Su nombre se debe a que el atacante toma archivos en formato “txt”, los que albergan miles de claves o usuarios, que son probados de modo automatizado hasta acertar con el par correcto.

A continuación, en Figura 2.1 se exponen los mensajes de alerta que Wazuh almacena en el servicio de indexación, donde de acuerdo con un comportamiento de intentos de autenticación, finalmente concluye que es un ataque de fuerza Bruta.

	timestamp	agent.name	rule.description	rule.level	rule.id
	Mar 8, 2025 @ 14:42:35.596	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.596	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.596	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.595	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.594	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.575	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.575	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.574	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.574	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.574	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.574	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.574	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.555	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.552	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 13:47:37.305	scada77	PAM: Login session closed.	3	5502

Figura 2.1. Registro de intentos de autenticación

Como se puede apreciar en la Figura 2.1, describe intentos de establecer una conexión SSH con un usuario que no existe. En particular y como se expone más adelante, las pruebas de concepto sugeridas por Wazuh [6], proponen opciones en que se usa un usuario no existente el que será descrito en los mensajes específicos de la alerta en cuestión.

	timestamp	agent.name	rule.description	rule.level	rule.id
	Mar 8, 2025 @ 14:42:35.656	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.655	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.655	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.635	scada77	PAM: Multiple failed logins in a small period of time.	10	5551
	Mar 8, 2025 @ 14:42:35.635	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.635	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.635	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.617	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.617	scada77	PAM: User login failed.	5	5503
	Mar 8, 2025 @ 14:42:35.617	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.617	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.617	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.617	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.615	scada77	sshd: Attempt to login using a non-existent user	5	5710
	Mar 8, 2025 @ 14:42:35.596	scada77	sshd: brute force trying to get access to the system. Non existent user.	10	5712

Figura 2.2. Registros de correlación entre fuerza bruta y utilización de usuario no existente.

Luego en la Figura 2.2 se observa que un ataque de fuerza Bruta está intentando obtener acceso al sistema con un usuario no existente.

Ahora en las siguientes imágenes se aprecian los detalles que entregan las alertas de Wazuh por defecto, los que son de interés para el monitoreo del host.

Table JSON

t _index	wazuh-alerts-4.x-2025.03.08
t agent.id	001
t agent.ip	192.168.122.156
t agent.name	scada77
t data.srcip	192.168.122.229
t data.srcport	42772
t data.srcuser	badguy
t decoder.name	sshd
t decoder.parent	sshd
t full_log	Mar 08 17:02:57 scada77 sshd[13337]: Invalid user badguy from 192.168.122.229 port 42772
t id	1741455755.78505
t input.type	log
t location	journald
t manager.name	wazuh-server
t predecoder.hostname	scada77
t predecoder.program_name	sshd

Figura 2.3 Detalle del reporte de alerta de ataque de fuerza bruta con usuario no existente.

En la Figura 2.3 se aprecia la dirección de origen del host que ejecuta el ataque (192.168.122.229), el usuario “badguy” señalado en el recuadro rojo de la figura 2.3 y un mensaje describiendo el día, hora, nombre del usuario host afectado y el servicio, y una breve descripción señalando la máquina atacante junto al puerto a través del cual se intentó el ataque.

2.3 Implementación IDS Suricata

Se implementa IDS Suricata para detectar tráfico de red malicioso a través de Wazuh. En este escenario se practicó desde la fase de Reconocimiento y escaneo activo, para verificar en que umbral de sensibilidad es capaz el IDS de alertar sobre tráfico malicioso.

En la primera etapa el atacante se ocupa de reconocer la red en la que se encuentra, y las direcciones IP que se encuentran en servicio en ella. Para ello el atacante mediante la máquina Kali Linux [9] introduce los siguientes comandos que se exponen en Figura 2.4:

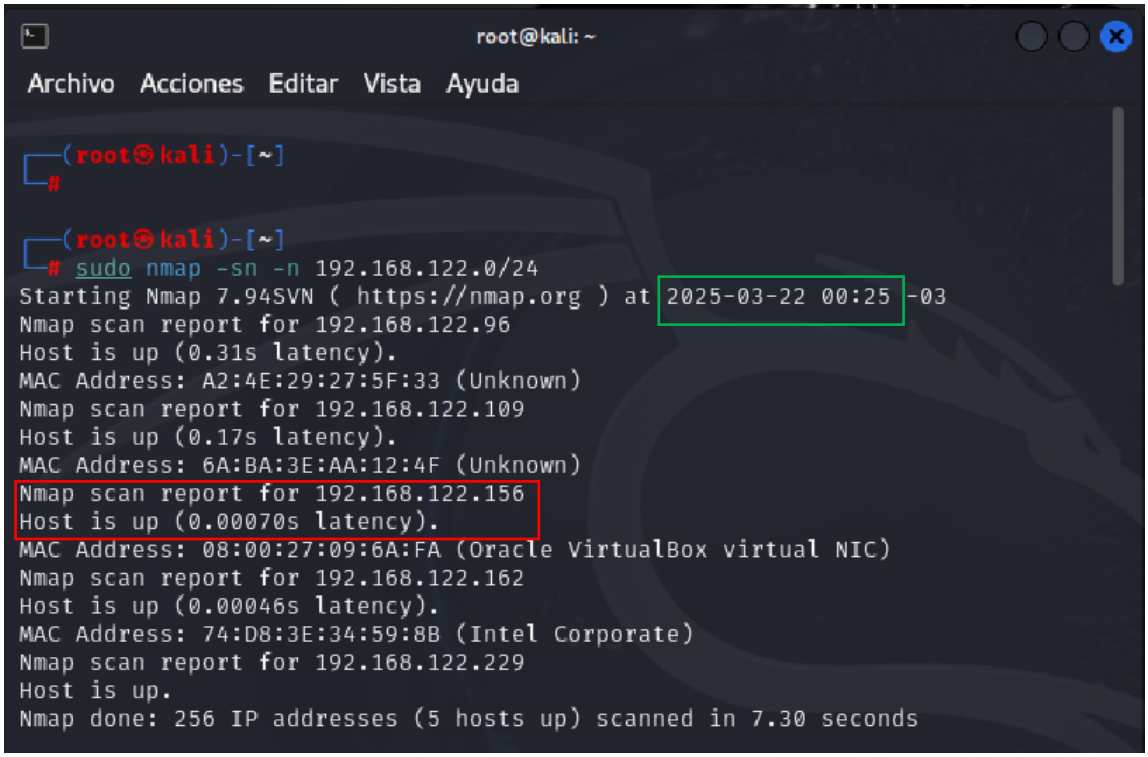


Figura 2.4 Identificación de la sub red.

En que se utilizó la herramienta de reconocimiento Nmap, usando los comandos **sudo nmap -sn -n 192.168.122.0/24**, señalados en recuadro de color naranja de la figura 2.4, donde los conmandos -sn es para enviar paquetes de red TCP vacíos y -n para no realizar escaneos en puertos los que permiten que únicamente confirmen la existencia de host, sin completar el intercambio de mensajes ARP y dando una confirmación de que host están en servicio. De entre ellos figura la dirección 192.168.122.156 señalada en el recuadro rojo, dirección a la cual enfocaremos nuestro siguiente análisis.

Posteriormente se utiliza Nmap [10] para realizar escaneo de puertos y servicios a la dirección IP 192.168.122.156 para investigar que servicios podría aprovechar el atacante.

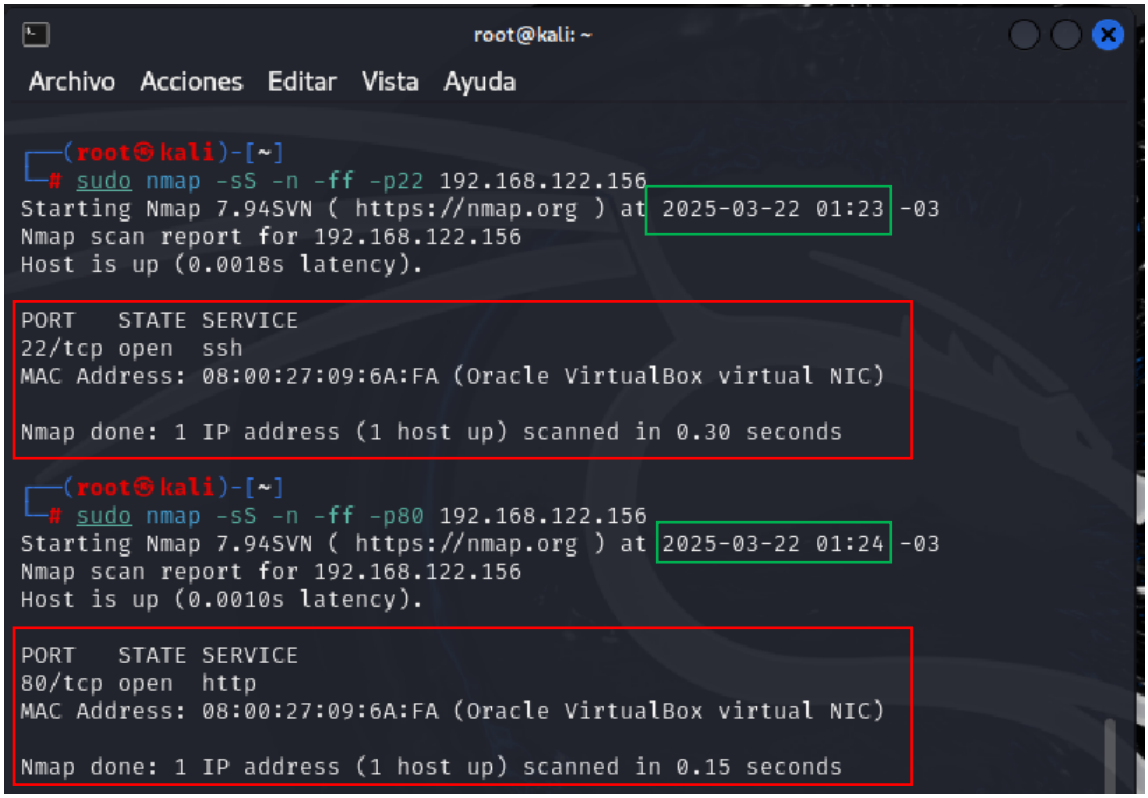


Figura 2.5 Identificación de puertos.

Donde se verifican en los recuadros rojos de la figura 2.5 donde el servicio ssh mediante el puerto 22 se encuentra abierto y el puerto 80 del servicio http se encuentra abierto y operativo.

NOTA : Hasta este punto Wazuh aún no ha sido capaz de descubrir el escaneo activo, puesto que el tráfico de red u otros comportamientos todavía no son tan significativos para que sean tomados en cuenta. Se recomienda al lector revisar las siguientes figuras y consultar los recuadros verdes en donde se indican horarios y día de ejecución (figuras 2.4 y 2.5) y pueda encontrar alguna alerta en las figuras 2.6ª y 2.7 siguientes. Por lo que se concluye de momento que el reconocimiento ha pasado aún desapercibido por IDS Suricata.

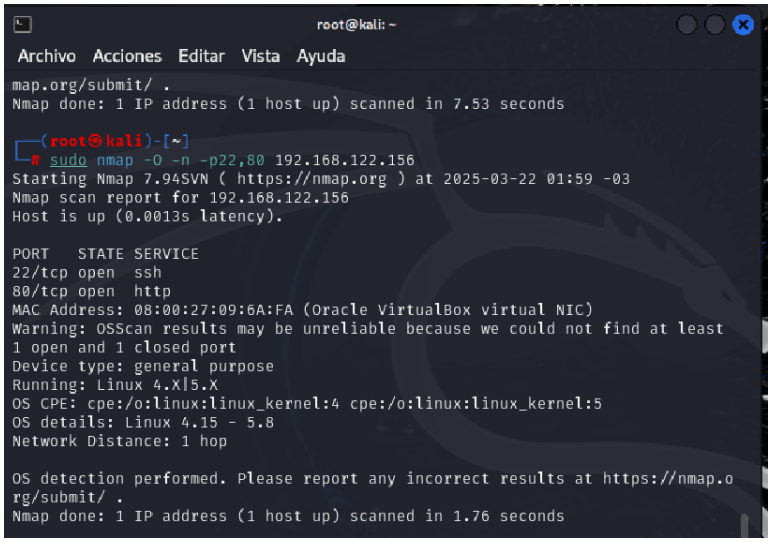
timestamp	agent.name	rule.description
Mar 22, 2025 @ 00:47:01.4...	scada77	Suricata: Alert - ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management
Mar 22, 2025 @ 00:47:01.4...	scada77	Suricata: Alert - ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management
Mar 22, 2025 @ 00:47:01.4...	scada77	Suricata: Alert - ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management
Mar 22, 2025 @ 00:47:01.2...	scada77	Apparmor DENIED
Mar 22, 2025 @ 00:47:00.6...	scada77	Listened ports status (netstat) changed (new port opened or closed).
Mar 22, 2025 @ 00:46:59.9...	scada77	Host-based anomaly detection event (rootcheck).
Mar 22, 2025 @ 00:46:59.9...	scada77	Host-based anomaly detection event (rootcheck).
Mar 22, 2025 @ 00:46:58.3...	scada77	File modified in /root directory.
Mar 18, 2025 @ 14:26:07.1...	scada77	Integrity checksum changed.
Mar 18, 2025 @ 14:26:07.1...	scada77	Integrity checksum changed.
Mar 18, 2025 @ 14:22:52.4...	scada77	Listened ports status (netstat) changed (new port opened or closed).
Mar 18, 2025 @ 14:16:51.2...	scada77	Host-based anomaly detection event (rootcheck).
Mar 18, 2025 @ 14:16:51.1...	scada77	Host-based anomaly detection event (rootcheck).
Mar 18, 2025 @ 14:16:46.9...	scada77	Wazuh agent started.
Mar 18, 2025 @ 14:16:44.5...	scada77	Wazuh agent stopped.

Figura 2.6a. Registro en el cual NO se alerta de actividad de red maliciosa.

timestamp	agent.name	rule.description	rule.level	rule.id
Mar 22, 2025 @ 01:27:03.1...	scada77	File modified in /root directory.	7	100200
Mar 22, 2025 @ 01:03:50.1...	scada77	VirusTotal: Alert - /root/.lesshst - No positives found	3	87104
Mar 22, 2025 @ 01:03:42.5...	scada77	PAM: Login session closed.	3	5502

Figura 2.7. Registro en el cual NO se alerta de actividad de red maliciosa.

Por último, en el proceso de escaneo de sistemas operativos, la actividad de escaneo activo si es descubierta por Wazuh mediante el IDS suricata implementado, con lo cual ya aportaría información valiosa para tomar medidas frente a esta amenazada de reconocimiento.



```
root@kali: ~
Archivo  Acciones  Editar  Vista  Ayuda
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.53 seconds

┌──(root㉿kali)-[~]
└─# sudo nmap -O -n -p22,80 192.168.122.156
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-22 01:59 -03
Nmap scan report for 192.168.122.156
Host is up (0.0013s latency).

PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:09:6A:FA (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.76 seconds
```

Figura 2.8. Escaneo activo para descubrir el sistema operativo objetivo.

	Mar 22, 2025 @ 02:22:35.5...	scada77	Suricata: Alert - ET SCAN NMAP OS Detection Probe	3	86601
	Mar 22, 2025 @ 02:22:35.5...	scada77	Suricata: Alert - ET SCAN Potential SSH Scan	3	86601
	Mar 22, 2025 @ 02:05:51.0...	scada77	Suricata: Alert - ET SCAN NMAP OS Detection Probe	3	86601
	Mar 22, 2025 @ 02:05:51.0...	scada77	Suricata: Alert - ET SCAN Potential SSH Scan	3	86601
	Mar 22, 2025 @ 02:05:49.2...	scada77	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Eng...	3	86601
	Mar 22, 2025 @ 02:05:49.2...	scada77	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Eng...	3	86601
	Mar 22, 2025 @ 02:05:49.2...	scada77	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Eng...	3	86601

Figura 2.9. Alertas de actividad maliciosa de consultas por sistema operativo.

Si el lector observa, hubo una diferencia de alrededor de 22 minutos (también debido a que por la capacidad del computador físico requiere conectar host y maquina Kali y después apagar alguna de ambas máquinas y conectar el servidor, para no generar colapso de memoria RAM en la máquina física) entre el horario que reporta la máquina virtual Kali Linux y lo que notifica Wazuh a través del IDS [2]. Sin embargo, el mensaje de alerta es claro en notificar que se están realizando escaneos a distintos servicios a través de Nmap [10] al sistema operativo y al servicio SSH en la figura 2.9, sin embargo no figuran mensajes específicos sobre escaneo al servicio http.

2.4 IMPLEMENTACION DE VIRUS TOTAL

En ocasiones para complementar el esfuerzo frente al contexto de amenazas, Wazuh puede combinar implementaciones con distintas herramientas y una de ellas es Virus Total [3]. En particular se realizará una prueba de funcionamiento de Virus Total con un archivo denominado EICAR, el que usualmente se utiliza para verificar la eficacia de las distintas herramientas de detección y respuesta frente a Malware.

Se comienza por crear un script de respuesta activa en la ruta **/var/ossec/active-response/bin/remove-threat.sh** del punto final Ubuntu donde se definen las identificaciones de las amenazas, comando para enviar los logs de alerta y posteriormente la acción de respuesta activa para remover la amenaza [3]: Lo que resulta en la detección y eliminación de amenaza de virus en el host monitoreado.

Luego de las configuraciones señaladas en el punto final, a continuación, se señalan algunas rutas de configuración para implementar Virustotal. Para mayor detalle sobre la configuración el lector podrá consultar el Anexo A.2:

/var/ossec/etc/rules/local_rules.xml:

Ruta en la que se configura la regla, se define el número ID de la misma y el directorio a monitorizar: En este caso /root.

/var/ossec/etc/ossec.conf :

Ruta en la que se habilita la integración con Virus total. En particular se convoca la clave de producto que se dispone al crear una cuenta de usuario en que se obtiene dicha clave de producto, para posteriormente ser activada y desplegada la solución de Virustotal en el servidor.

/var/ossec/etc/ossec.conf :

En la presente ruta se configura la respuesta activa del script de respuesta activa para remover el archivo infectado.

Luego de las fases de configuración tanto en servidor como punto final, se emplea el siguiente comando en una terminal en el host Ubuntu:

sudo curl -Lo /root/eicar.com https://secure.eicar.org/eicar.com && sudo ls -lah /root/eicar.com

El que descarga EICAR, un archivo que, si bien tienen rasgos claros de amenaza, su módulo de ejecución se encuentra inactivo, por lo que es creado especialmente para realizar pruebas en distintos sistemas operativos sin mayores consecuencias.

A continuación, se exponen los logs de alerta de las acciones informativas y de eliminación de EICAR en el host Ubuntu en la Figura 2.10:

	Mar 18, 2025 @ 11:18:25.5...	scada77	active-response/bin/remove-threat.sh removed threat located at /root/eicar.com	12	100092
	Mar 18, 2025 @ 11:18:25.1...	scada77	File deleted.	7	553
	Mar 18, 2025 @ 11:18:24.9...	scada77	VirusTotal: Alert - /root/eicar.com - 67 engines detected this file	12	87105

Figura 2.10. Detección de archivo EICAR y mensajes de respuesta activa aplicada al archivo malicioso.

Si se revisa el detalle del primer log en aparecer, en este caso la detección de EICAR, se obtienen los siguientes detalles:

Table JSON

t _index	wazuh-alerts-4.x-2025.03.18
t agent.id	001
t agent.ip	192.168.122.156
t agent.name	scada77
t data.integration	virustotal
t data.virustotal.found	1
t data.virustotal.malicious	1
t data.virustotal.permalink	https://www.virustotal.com/gui/file/275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f/detection/f-275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f-1742307466
t data.virustotal.positives	67
t data.virustotal.scan_date	2025-03-18 14:17:46

Figura 2.11. Detalle del mensaje de alerta y repositorio de información de amenazas de virustotal.

Donde el mensaje de la Figura 2.11 muestra un enlace de la base de datos de Virustotal [3], donde correlaciona la capacidad de detección y compara con las demás herramientas de detección y respuesta ante presencia de Virus.

AhnLab-V3	Virus/EICAR_Test_File	Alibaba	Virus:Win32/EICAR.A
AliCloud	Engtest:Multi/Eicar	ALYac	Misc.Eicar-Test-File
Antiy-AVL	TestFile/Win32.EICAR	Arcabit	EICAR-Test-File (not A Virus)
Avast	EICAR Test-NOT Virus!!!	Avast-Mobile	Eicar
AVG	EICAR Test-NOT Virus!!!	Avira (no cloud)	Eicar-Test-Signature
Baidu	Win32.Test.Eicar.a	BitDefender	EICAR-Test-File (not A Virus)
Bkav Pro	W32.EicarTest.Trojan	ClamAV	Win.Test.EICAR_HDB-1
CTX	Txt.virus.eicar	Cynet	Malicious (score: 99)
DrWeb	EICAR Test File (NOT A Virus!)	Elastic	Eicar
Emsisoft	EICAR-Test-File (A)	eScan	EICAR-Test-File
ESET-NOD32	Eicar Test File	Fortinet	EICAR_TEST_FILE
GData	EICAR_TEST_FILE	Google	Detected
Gridinsoft (no cloud)	Trojan.U.EICAR_Test_File.dd	Huorong	TEST/AVEngTestFile!EICAR

Figura 2.12. Base de datos de VirusTotal [3] donde indica base de datos de herramientas anti virus y antimalware y capacidad de detección de archivo de pruebas EICAR.

Siendo los archivos EICAR indicados en rojo, en la Figura 2.12, los mensajes que indican que determinadas soluciones antivirus han sido capaces de detectar el archivo malicioso.

Webroot	W32.Eicar.Testvirus.Gen	WithSecure	EICAR_Test_File
Xcitium	Malware@#2975xfk8s2pq1	Yandex	EICAR_test_file
Zillya	EICAR.TestFile	ZoneAlarm by Check Point	EICAR-AV-Test
Zoner	EICAR.Test.File-NoVirus.250	Acronis (Static ML)	Undetected
CMC	Undetected	CrowdStrike Falcon	Undetected
MaxSecure	Undetected	BitDefenderFalx	Unable to process file type

Figura 2.13. Softwares que no detectan rasgos de EICAR como archivo malicioso en verde, según base de datos de VirusTotal [3].

Y los mensajes en color verde, de la Figura 2.13, que indican que determinadas herramientas señaladas aún siguen sin poder detectar el archivo malicioso EICAR.

Por otra parte, los mensajes siguientes indicados en Figura 2.14, exponen la eliminación del archivo, con el siguiente mensaje de detalle:

Table JSON

t	_index	wazuh-alerts-4.x-2025.03.18
t	agent.id	001
t	agent.ip	192.168.122.156
t	agent.name	scada77
t	decoder.name	syscheck_deleted
t	full_log	File '/root/eicar.com' deleted Mode: realtime
t	id	1742307505.71568
t	input.type	log
t	location	syscheck
t	manager.name	wazuh-server
t	rule.description	File deleted.
#	rule.firedtimes	1
t	rule.gdpr	II_5.1.f
t	rule.gpg13	4.11
t	rule.groups	ossec, syscheck, syscheck_entry_deleted, syscheck_file

Figura 2.14. Mensaje de respuesta activa de eliminación de EICAR del host Ubuntu.

Donde indica la ruta en que fue detectado y removido en el recuadro de color rojo de la Figura 2.14.

t	input.type	log
t	location	syscheck
t	manager.name	wazuh-server
t	rule.description	File deleted.
#	rule.firedtimes	1
t	rule.gdpr	II_5.1.f
t	rule.gpg13	4.11
t	rule.groups	ossec, syscheck, syscheck_entry_deleted, syscheck_file
t	rule.hipaa	164.312.c.1, 164.312.c.2
t	rule.id	553
#	rule.level	7
◐	rule.mail	false
t	rule.mitre.id	T1070.004 T1485
t	rule.mitre.tactic	Defense Evasion, Impact
t	rule.mitre.technique	File Deletion, Data Destruction

Figura 2.15. Clasificación de cualidad de amenazas de EICAR según MITRE.

Y en la Figura 2.15 indica una descripción mediante el marco de tácticas de amenazas de Mitre [], donde si se profundiza en las reglas de mitre identificadas, se exponen características del archivo malicioso, en donde se realiza eliminación de información, ya sea de información que sea de importancia para el propietario o bien que sirva para borrar el rastro de intrusión.

2.5 DETECCION DE RASGOS DE DOS A TRAVÉS DE IDS SURICATA

En la presente sección se expone una forma de lograr un DOS a través de una herramienta integrante de las máquinas virtuales Kali Linux denominada “hping3”. Hpin3 tiene una serie de formas y de variantes que, conforme a las necesidades del atacante y las características del sistema de las cuales el atacante haya sido capaz de reconocer en las fases de escaneo pasivo y activo llevadas a cabo anteriormente, usará para generar los efectos deseados en un determinado sistemas, host o servicio de este.

Para ejecutar las características del ataque de denegación de servicio (conocido como DOS) desde la máquina virtual Kali Linux, se usará el siguiente comando:

```
hping3 --icmp --rand-source --flood -d 1401 192.168.122.156
```

Figura 2.16. Comando herramienta hping3 en Kali Linux para ensayo de DOS en Host Ubuntu.

Donde:

Hping3: Es la herramienta invocada para iniciar el ataque DOS en el ensayo.

--icmp: Es el protocolo utilizado por el comando ping, para comprobar comunicaciones de redes entre dos host en una subred privada, por ejemplo.

--rand-source: Es la función que permite variar la dirección IPv4 de origen del ataque, haciéndola variar de una dirección IP en otra.

--flood: Es el comando que dispone la mayor velocidad posible el envío de paquetes ICMP para inundar de peticiones el Host en cuestión.

-d: Es el comando que asigna una determinada longitud de bytes para generar paquetes ICMP con un mayor peso de información y aporte a la realentización o desborde de memoria de procesamiento del Host objetivo. En este caso envía 1401 bytes de carga maliciosa.

Dirección IPv4: Es la dirección del Host objetivo para el cual se pretende lograr el ataque DOS.

Si bien en la explicación de la herramienta de la máquina virtual Kali Linux resulta difícil concebir que Wazuh como SIEM por defecto no sería capaz de evaluar o detectar un ataque de tales características, lo cierto es que si detecta patrones de comportamiento tanto del flujo de los paquetes de red, puertos a los que son dirigidos al host objetivo, además de reportar desbordamiento de eventos en el agente, entre otros.
El lector notará que en cualquier caso Wazuh solo es capaz de detectar el origen que le dicta la herramienta hping3, y pese a ellos la plataforma es capaz de reconocer un patron de comportamiento sospechoso frente al tráfico de red a través del IDS Suricata.

A continuación, se expone una imagen con los primeros mensajes entregados por el IDS Suricata:

Export Formatted | 755 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Apr 6, 2025 @ 21:45:56.344	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 24	3	86601
Apr 6, 2025 @ 21:45:56.344	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 23	3	86601
Apr 6, 2025 @ 21:45:56.335	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 14	3	86601
Apr 6, 2025 @ 21:45:56.334	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 25	3	86601
Apr 6, 2025 @ 21:45:56.333	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 24	3	86601
Apr 6, 2025 @ 21:45:56.333	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 36	3	86601
Apr 6, 2025 @ 21:45:56.333	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 43	3	86601
Apr 6, 2025 @ 21:45:56.325	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 39	3	86601
Apr 6, 2025 @ 21:45:56.323	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 20	3	86601
Apr 6, 2025 @ 21:45:56.320	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 20	3	86601
Apr 6, 2025 @ 21:45:56.319	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 18	3	86601
Apr 6, 2025 @ 21:45:56.319	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 18	3	86601
Apr 6, 2025 @ 21:45:56.310	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 18	3	86601
Apr 6, 2025 @ 21:45:56.308	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 18	3	86601
Apr 6, 2025 @ 21:45:56.306	scada77	Suricata: Alert - ET DROP Spamhaus DROP Listed Traffic Inbound group 14	3	86601

Figura 2.17. Detección de tráfico de red sospechoso.

Si se revisa alguno de estos logs, de la Figura 2.17, daremos cuenta de que en cada uno de ellos hay una dirección IP distinta de origen del ataque para cada uno de ellos (que apela al comando -–rand-source de hping3)

t	data.alert.rev	4281
t	data.alert.severity	2
t	data.alert.signature	ET DROP Spamhaus DROP Listed Traffic Inbound group 20
t	data.alert.signature_id	2400019
t	data.dest_ip	192.168.122.156
t	data.dest_port	0
t	data.direction	to_server
t	data.event_type	alert
t	data.flow.bytes_toclient	0
t	data.flow.bytes_toserver	1443
t	data.flow.dest_ip	192.168.122.156
t	data.flow.pkts_toclient	0
t	data.flow.pkts_toserver	1
t	data.flow.src_ip	137.72.211.58
t	data.flow.start	2025-04-06T18:38:55.605019-0400
t	data.flow_id	2035590280265951.000000
t	data.icmp_code	0
t	data.icmp_type	8

Figura 2.18. Evidencia de dirección IPv4 de origen distinta a la dirección del atacante.

t	data.alert.rev	4281
t	data.alert.severity	2
t	data.alert.signature	ET DROP Spamhaus DROP Listed Traffic Inbound group 36
t	data.alert.signature_id	2400035
t	data.dest_ip	192.168.122.156
t	data.dest_port	0
t	data.direction	to_server
t	data.event_type	alert
t	data.flow.bytes_toclient	0
t	data.flow.bytes_toserver	1443
t	data.flow.dest_ip	192.168.122.156
t	data.flow.pkts_toclient	0
t	data.flow.pkts_toserver	1
t	data.flow.src_ip	193.139.86.194

Figura 2.19. Segunda comprobación de que dirección IPv4 no corresponde a la dirección del atacante.

Como se aprecia en las imágenes anteriores (Figuras 2.18 y 2.19), se indican las direcciones 137.72.211.58 y 192.139.86.194, como las direcciones IP de origen del atacante, siendo la dirección IP 192.168.122.229 la dirección real de la máquina atacante.

En una segunda etapa de los registros durante el ensayo, se verifica el colapso de la memoria del agente Wazuh desplegado en la máquina Ubuntu 24.04, donde los logs indican que el buffer del agente está al borde de colapso, alrededor de 90%, en los registros de indexación del servidor Wazuh, respecto al agente que monitorea el Host Ubuntu. Luego indica en los mensajes que es probable de que se haya perdido la capacidad del agente de registrar otros eventos dado el colapso. A continuación, las siguientes imágenes lo indican (Figuras 2.20 y 2.21):

Table JSON

t	_index	wazuh-alerts-4.x-2025.04.07
t	agent.id	001
t	agent.ip	192.168.122.156
t	agent.name	scada77
t	data.level	90%
t	decoder.name	wazuh
t	decoder.parent	wazuh
t	full_log	wazuh: Agent buffer: '90%'.
t	id	1743990568.312051
t	input.type	log
t	location	wazuh-agent
t	manager.name	wazuh-server
t	rule.description	Agent event queue is 90% full.
#	rule.firedtimes	1
t	rule.gdpr	IV_35.7.d
t	rule.groups	wazuh, agent_flooding

Figura 2.20. Desbordamiento de eventos en memoria de agente wazuh.

Table JSON

t _index	wazuh-alerts-4.x-2025.04.07
t agent.id	001
t agent.ip	192.168.122.156
t agent.name	scada77
t data.level	full
t decoder.name	wazuh
t decoder.parent	wazuh
t full_log	wazuh: Agent buffer: 'full'.
t id	1743990572.312765
t input.type	log
t location	wazuh-agent
t manager.name	wazuh-server
t rule.description	Agent event queue is full. Events may be lost.

Figura 2.21. Memoria de Agente wazuh ssturada por efectos de DOS.

Por último y para finalizar con los efectos del ataque DOS a la máquina virtual Ubuntu 24.04, se muestran los efectos en sistema, como por ejemplo el desbordamiento del procesador de la máquina. A continuación, se expone una imagen con la maquina Ubuntu en servicio normal (Figura 2.22) y luego una con los efectos del ataque manifestado en el aumento de uso del procesador (Figura 2.23):

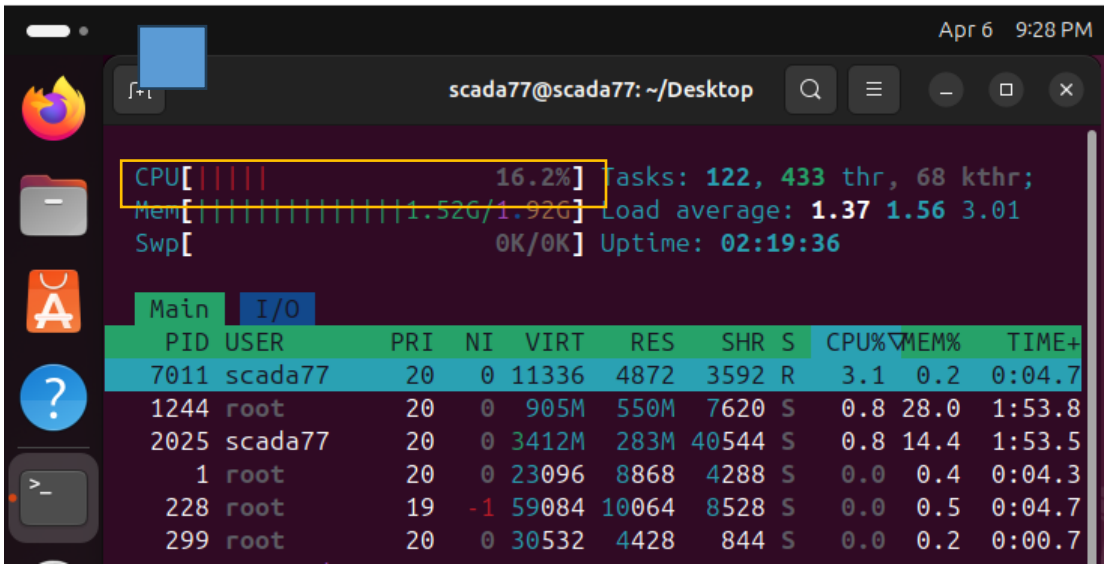


Figura 2.22. Procesador en operación normal, indicado en recuadro dorado.

Luego durante el ataque DOS:

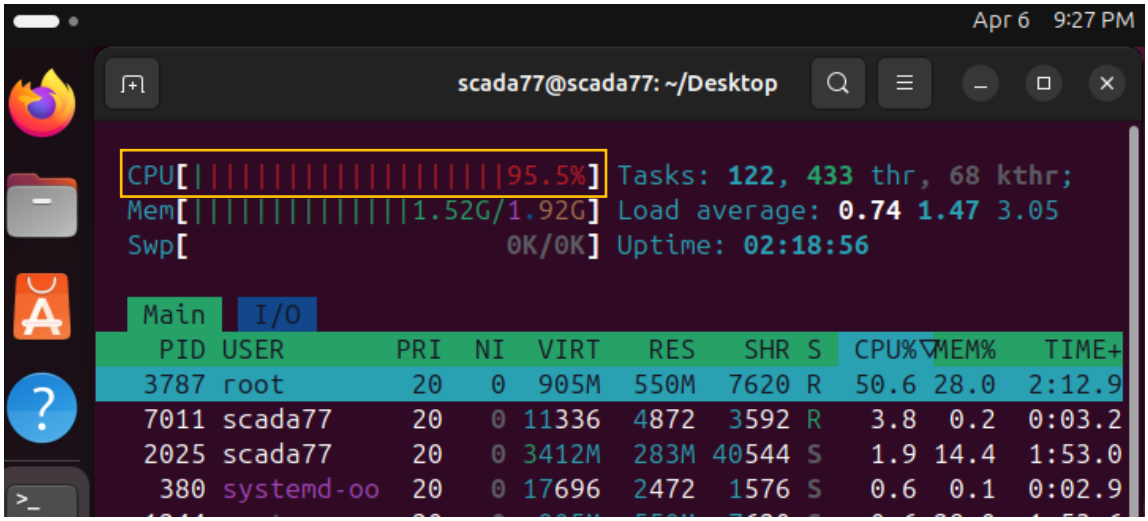


Figura 2.23. Desbordamiento de procesador de Host Ubuntu.

Para uno de los ensayos realizados, el que se expone obtuvo como resultado la saturación sintomática de la máquina Ubuntu que se expresó en forzar el cierre del navegador Firefox en la misma máquina, como se aprecia en la siguiente imagen (Figura 2.24):

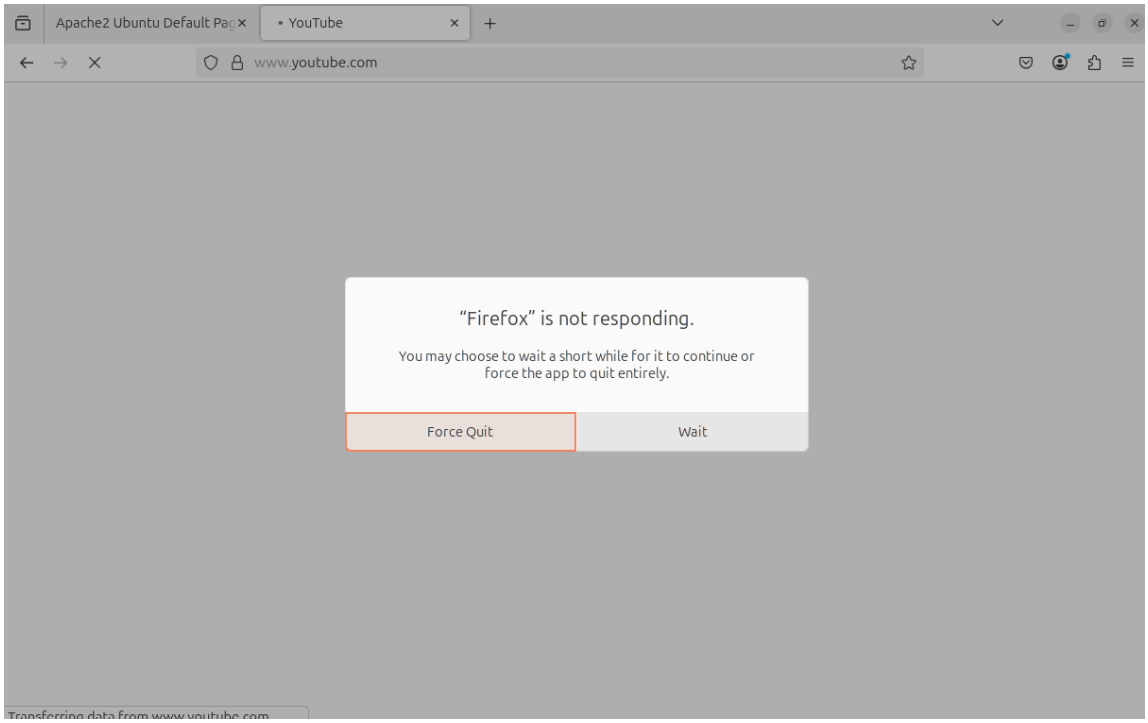


Figura 2.24. Efecto de paralización de Host cuando se solicita servicio de internet en firefox.

Y en un segundo ensayo, se varió la capacidad de la memoria RAM de la máquina virtual, de 2 GB a 4GB. Si bien el ataque DOS no fue del todo exitoso, se logró en un momento dado por parte de la máquina atacante, negar el acceso a una página web:

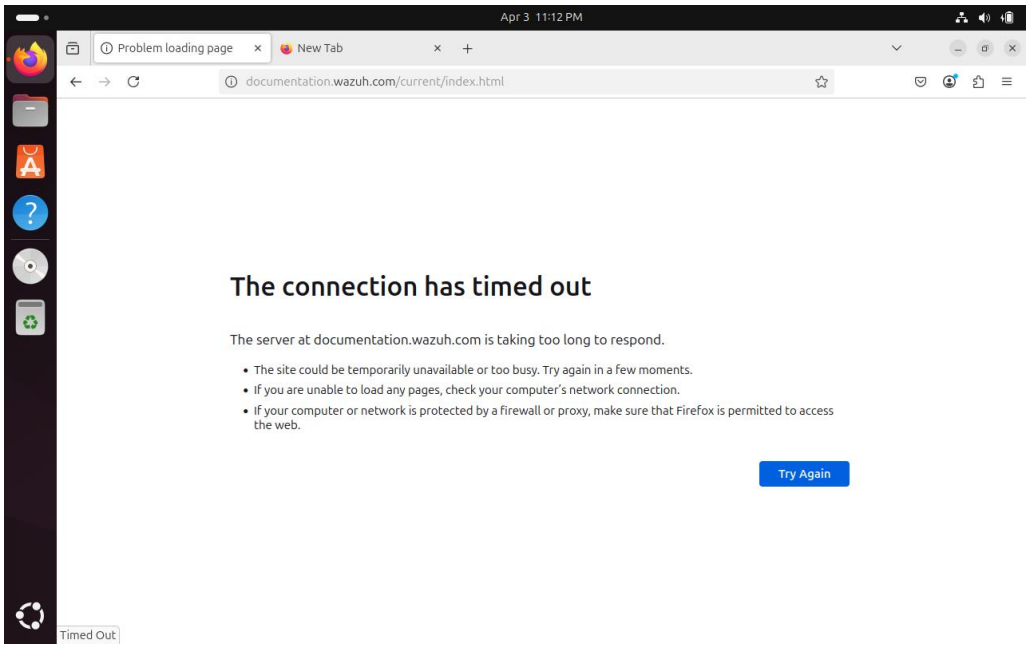


Figura 2.25. Tiempo de respuesta superado, síntoma usual de un DOS en un sitio web.

En el presente caso a la página misma de wazuh.

CAPÍTULO 5

CONCLUSIONES

Se ha podido constatar mediante ensayo la capacidad y sensibilidad para detectar comportamientos anómalos por parte de Wazuh [6], en cuanto a tráfico anómalo de red, a través del IDS suricata [2].

Si bien los objetivos generales propuestos en el presente trabajo de titulación no se cumplen desde el punto de vista de frustrar o bloquear de manera automática un actor malicioso o malware que produzca como efecto una denegación de servicio, en un Host crítico para el funcionamiento de una red industrial que controle un sistema de generación de energía eléctrica, se rescata el hecho de que para Wazuh [6] no pasa desapercibido el tráfico totalmente, por lo que, aún con resultados de un ataque que produzcan consecuencias negativas para la disponibilidad de servicio eléctrico, se conservará un registro de los eventos que describen con precisión los eventos ocurridos en tiempo real en el Host monitoreado a través del servidor de Wazuh, por lo que un equipo que monitoree los eventos dispondrá en tiempo real las alertas para interpretar patrones de ataque y poder tomar decisiones basadas en ellos y poder resguardar la red SCADA y se tendrá disponibilidad de eventos que permitan realizar el seguimiento y tareas forenses en los dispositivos afectados. Aún así y lo que se considera en el diseño para brindar mayor seguridad a las redes SCADA que operan los procesos de generación de energía, se propone una estrategia de “diodo de datos”, lo que permite “aislar” un porcentaje de la red SCADA de la interacción de un posible atacante que haya tenido éxito en infiltrarse en la red. En este sentido se hace presente que la aislación que securiza una parte de la red SCADA viene dado por dos aspectos técnicos descritos en el trabajo de título: La separación de las interfaces y su configuración remota a través del intercambio de señales de modo óptico al interior del diodo de datos, y que la configuración del mismo diodo solo es posible a través de FPGA y con un cable de red físico en el dispositivo, con lo que se requiere siempre una intervención presencial, además de que dicho diodo solo opera en función de “transión”, desde la red SCADA aislada, hacia el resto de la red que interactúa con otras redes, sean estas corporativas o con acceso inmediato a navegación de internet.

Trabajos futuros:

- Profundizar en reglas que puedan brindar una precisión mas literal de un ataque de denegación de servicio como lo es el formato de inundación de paquetes ICMP en el Host.
- Realizar experiencias con herramientas como Splunk en combinación con Wazuh, para estudiar las capacidades de respuesta ante ataques de denegación de servicio y combinar la experiencia con otros elementos como Firewalls que estén distribuidos como se sugiere en el modelo Purdue [7].
- Experimentar con Wazuh en redes más extensas y con más Host que se encuentren monitoreados por un agente Wazuh, y poder medir en una subred con más agentes disponibles y medir la experiencia de correlación de eventos (función XDR de Wazuh).
- Realizar auditorías en redes SCADA que consideren la realización de movimiento lateral de un atacante y medir dicha experiencia para monitorear las capacidades de Wazuh frente a ese escenario: Si bien Wazuh tiene una visibilidad bastante solvente, en el sentido de que puede monitorear actividad legítima de configuraciones que requieren alto nivel de autoridad, será un nuevo aporte el hecho de poder agregar capacidades de correlación de eventos y distinguir el movimiento lateral, una vez que el atacante se encuentre infiltrado.

GLOSARIO

Malware:

Es un programa de código maligno, creado a partir de un lenguaje de programación, utilizado para distintas actividades ilegítimas por parte de un atacante de las redes de comunicación, generando por efecto las siguientes acciones: Utilizando varios ordenadores para inundar un sitio web de solicitudes de conexión y así negar el servicio a usuarios legítimos, secuestrar información sensible (como la información personal), generar mal funcionamiento de determinados elementos de un procesos industrial.

Ataque DOS:

Ataque de denegación de servicio (en inglés: Denia lof Service), es un ataque de red centrado en impedir que los usuarios accedan a los recursos de la red bajo ataque.

Ataque DDOS:
Ataque distribuido de denegación de servicio (Distributed Denia of Service).

SIC:
Acrónimo utilizado para referirse al “Sistema Interconectado Central” de la nación.

SCADA:
Acrónimo de Supervisory Control and Data Acquisitionn en idioma inglés, que quiere decir: Control de Supervisión y Adquisición de Datos.

HOST:
Se denomina Host para efectos del presente trabajo, a las computadoras con un determinado sistema operativo (en el caso de experimentación el sistema Ubuntu) y que tendrían en el caso presentado control sobre redes industriales SCADA.

REFERENCIAS BIBLIOGRÁFICAS

[1] Proof of concept guide https://documentation.wazuh.com/current/proof-of-concept-guide/index.html.

[2] Network IDS integration, https://documentation.wazuh.com/current/proof-of-concept-guide/integrate-network-ids-suricata.html.

[3] Detecting and removing malware using VirusTotal integration, https://documentation.wazuh.com/current/proof-of-concept-guide/detect-remove-malware-virustotal.html.

[4] Detecting a brute-force attack, https://documentation.wazuh.com/current/proof-of-concept-guide/detect-brute-force-attack.html.

[5] Wazuh Overview, https://wazuh.com/platform/overview/.

[6] Wazuh , https://wazuh.com/

[7] David Dolezilek, Dennis Gammel, William Fernandes. 15th International Conference on Developments in Power System Protection (DPSP 2020). “CYBERSECURITY BASED ON IEC 62351 AND IEC 62443 FOR IEC 61850 SYSTEMS”.

[8] Gestor de máquinas virtuales VirtualBox, https://www.virtualbox.org/

[9] Kali Linux, https://www.kali.org/

[10] Nmap, https://nmap.org/

ANEXO A

CONFIGURACION DE HERRAMIENTAS DE WAZUH

A.1 IMPLEMENTACIÓN Y CONFIGURACIÓN IDS SURICATA

A continuación, y según la guía de concepto de instalación de IDS Suricata, se comienza por instalar Suricata en el Host:

```
$ sudo add-apt-repository ppa:oisf/suricata-stable
$ sudo apt-get update
$ sudo apt-get install suricata -y
```

Luego se procede a descargar el conjunto de reglas que deberá aportar el agente Wazuh al servidor para generar los mensajes de alerta que correspondan;

- **cd /tmp/ && curl -LO https://rules.emergingthreats.net/open/suricata-6.0.8/emerging.rules.tar.gz**
- **sudo tar -xvzf emerging.rules.tar.gz && sudo mkdir /etc/suricata/rules && sudo mv rules/*.rules /etc/suricata/rules/**
- **sudo chmod 640 /etc/suricata/rules/*.rules.**

Una vez instalado Suricata en el Host, se procede a acceder al archivo suricata.yaml, a través de la ruta **etc/suricata/suricata.yaml**, para modificar las siguientes variables:

```
HOME_NET: "<UBUNTU_IP>"
EXTERNAL_NET: "any"

default-rule-path: /etc/suricata/rules
rule-files:
- "*.rules"

# Global stats configuration
stats:
enabled: yes

# Linux high speed capture support
af-packet:
  - interface: enp0s3
```

Usualmente y como parte de la experiencia realizada, solamente fue necesario insertar la dirección IP del mismo Host que será monitoreado. A continuación se muestra la dirección IPv4 donde se configuró dicha dirección en el Hosto Ubuntu:

```
scada77@scada77: /etc/suricata
  GNU nano 7.2                    suricata.yaml
suricata-version: "7.0"

##
## Step 1: Inform Suricata about your network
##

vars:
  # more specific is better for alert accuracy and performance
  address-groups:
    HOME_NET: "[192.168.122.156]"
    #HOME_NET: "[192.168.0.0/16]"
    #HOME_NET: "[10.0.0.0/8]"
    #HOME_NET: "[172.16.0.0/12]"
    #HOME_NET: "any"

    EXTERNAL_NET: "!$HOME_NET"
    #EXTERNAL_NET: "any"

    HTTP_SERVERS: "$HOME_NET"
    SMTP_SERVERS: "$HOME_NET"

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^/ Go To Line
```

Luego se reinicia el servicio de Suricata en el host a través de la terminal:

```
$ sudo systemctl restart suricata
```

Después de haber habilitado las configuraciones correspondientes al IDS Suricata, se procede a agregar en el archivo ossec.conf, a través de la ruta **/var/ossec/etc/ossec.conf**, la siguiente configuración, de tal manera de que Wazuh pueda leer los mensajes de suricata y presentarlo en formato JSON.

```
root@scada77: /var/ossec/etc
GNU nano 7.2                    ossec.conf

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/ossec/logs/active-responses.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/dpkg.log</location>
  </localfile>

</ossec_config>

<ossec_config>
  <localfile>
    <log_format>json</log_format>
    <location>/var/log/suricata/eve.json</location>
  </localfile>
</ossec_config>

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^/ Go To Line
```

Para finalmente reiniciar el servicio del agente Wazuh mediante el comando:

```
$ sudo systemctl restart wazuh-agent
```

Luego de estos pasos el IDS Suricata estará completamente operativo. Como se aprecia no ha sido necesario habilitar configuración alguna mas que en el Host a ser monitoreado.

A.2 CONFIGURACION DE VIRUSTOTAL

A.2.1 CONFIGURACIÓN DE VIRUSTOTAL EN HOST

En los manuales de Wazuh y guias de implementación, se comienza por solicitar al usuario que verifique que el servicio de integridad de archivo esté habilitado. Si bien en versiones anteriores este servicio no siempre se encontraba encendido, en la versión 4.10 (usada para el presente documento) se encuentra habilitado. Por lo que se prosigue a agregar dentro del bloque XML de syschek, el directorio que se desea monitorear en tiempo real. En este caso el directorio /root del Host bajo monitoreo.

```
root@scada77: /var/ossec/etc
GNU nano 7.2                                                    ossec.conf
</sca>

<!-- File integrity monitoring -->
<syscheck>
  <disabled>no</disabled>

  <!-- Frequency that syscheck is executed default every 12 hours -->
  <frequency>7</frequency>

  <scan_on_start>yes</scan_on_start>

  <!-- Directories to check  (perform all possible verifications) -->
  <directories>/etc,/usr/bin,/usr/sbin</directories>
  <directories>/bin,/sbin,/boot</directories>
  <directories realtime="yes">/root</directories>
```

Luego en la terminal del Host Ubuntu, se procede a instalar la función jq, que permitirá interpretar en JSON el script de respuesta activa que se activará en el Host, a través de los siguientes comandos:

```
$ sudo apt update
$ sudo apt -y install jq
```

A continuación y como se muestra en la fig se procede a ingresar a la ruta **/var/ossec/active-response/bin/remove-threat.sh,** y en el archivo remove-threat.sh se introducirá el script de respuesta activa de VirusTotal.

```
root@scada77: /var/ossec/active-response/bin
root@scada77:/var/ossec/active-response/bin# ls
default-firewall-drop  firewall-drop   ipfw          npf               restart.sh     wazuh-slack
disable-account        host-deny       kaspersky     pf                restart-wazuh  yara.sh
firewalld-drop         ip-customblock  kaspersky.py  remove-threat.sh  route-null
root@scada77:/var/ossec/active-response/bin# nano remove-threat.sh
root@scada77:/var/ossec/active-response/bin#
```

```
root@scada77: /var/ossec/active-response/bin
  GNU nano 7.2                                remove-threat.sh
#!/bin/bash

LOCAL=`dirname $0`;
cd $LOCAL
cd ../

PWD=`pwd`

read INPUT_JSON
FILENAME=$(echo $INPUT_JSON | jq -r .parameters.alert.data.virustotal.source.file)
COMMAND=$(echo $INPUT_JSON | jq -r .command)
LOG_FILE="${PWD}/../logs/active-responses.log"

#------------------------- Analyze command -------------------------#
if [ ${COMMAND} = "add" ]
then
 # Send control message to execd
 printf '{"version":1,"origin":{"name":"remove-threat","module":"active-response"},"command":"check_keys", "parameters">

 read RESPONSE
 COMMAND2=$(echo $RESPONSE | jq -r .command)
 if [ ${COMMAND2} != "continue" ]
 then
  echo "`date '+%Y/%m/%d %H:%M:%S'` $0: $INPUT_JSON Remove threat active response aborted" >> ${LOG_FILE}
  exit 0;
 fi
fi

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo      M-A Set Mark
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo      M-6 Copy
```

Después de crear el archivo e insertar el script de respuesta activa, se procede a asignar los permisos que corresponden al archivo, con los siguientes comandos:

```
$ sudo chmod 750 /var/ossec/active-response/bin/remove-threat.sh
$ sudo chown root:wazuh /var/ossec/active-response/bin/remove-threat.sh
```

Para finalmente reiniciar el agente Wazuh:

```
$ sudo systemctl restart wazuh-agent
```

A.2.2 CONFIGURACIÓN DE VIRUSTOTAL EN SERVIDOR WAZUH

Luego del proceso de configuración de detección y respuesta activa de malware en el Host, se procede a habilitar las reglas necesarias en el servidor y poder habilitar Virustotal a través de clave de producto, la ejecución del archivo remove-threat.sh y los mensajes correspondientes de las acciones tomadas y de monitoreo.

Las primeras reglas alertan sobre cambios en el directorio /root del Host Ubuntu.
Para ello se procede a la siguiente ruta **/var/ossec/etc/rules/local_rules.xml** y se agregan los siguientes encabezados en XML.

```
Wazuh v4.10.1 OVA [Corriendo] - Oracle VirtualBox
Archivo   Máquina   Ver   Entrada   Dispositivos   Ayuda
  GNU nano 2.9.8                    local_rules.xml

<group name="syscheck,pci_dss_11.5,nist_800_53_SI.7,">
  <!-- Rules for Linux systems -->
  <rule id="100200" level= "7">
    <if_sid>550</if_sid>
    <field name="file">/root</field>
    <description>File modified in /root directory.</description>
  </rule>

  <rule id="100201" level="7">
    <if_sid>554</if_sid>
    <field name="file">/root</field>
    <description>File added to /root directory.</description>
  </rule>
</group>
```

Luego se agrega la integración de VirusTotal junto con la clave de producto dentro de la estructura de texto XML:

```
<ossec_config>
  <integration>
    <name>virustotal</name>
    <api_key>23ef187d0f5e459cf12d4f0da0d387c92ebfc7d83518c67ee697f5fd811972fd</$
    <rule_id>100200,100201</rule_id>
    <alert_format>json</alert_format>
  </integration>

  <command>
    <name>remove-threat</name>
    <executable>remove-threat.sh</executable>
```

Luego se configura la respuesta activa y así activar el script una vez detectada la amenaza

```
<command>
  <name>remove-threat</name>
  <executable>remove-threat.sh</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>remove-threat</command>
  <location>local</location>
  <rules_id>87105</rules_id>
</active-response>
```

Finalmente se configuran los mensajes que confirman los resultados de la respuesta activa de wazuh:

```
<group name="virustotal,">
  <rule id="100092" level="12">
    <if_sid>657</if_sid>
    <match>Successfully removed threat</match>
    <description>$(parameters.program) removed threat located at $(parameters.a$
  </rule>

  <rule id="100093" level="12">
    <if_sid>657</if_sid>
    <match>Error removing threat</match>
    <description>Error removing threat located at $(parameters.alert.data.virus$
  </rule>
</group>
```